

Pampered Pets

Risk Identification Report

Prepared by: CySec UKUAE Team, Security and Risk Management Consultancy

Date: 5 June 2026

Team Members (Group 2): Peer C and Séba Daher

Peer names redacted for publication

1. Introduction.....	2
2. Methodology.....	2
3. Current business state risk assessment.....	2
Key risks (likelihood x impact):	3
Priority mitigations:	3
4. Digitalisation state risk assessment.....	4
STRIDE applied to the proposed e-commerce data flow (Shostack, 2014):	4
Key risks (likelihood x impact):	4
Priority mitigations:	5
5. Recommendation.....	6
6. Conclusion	6
References.....	7

Link to tutor feedback: <https://www.my-course.co.uk/mod/assign/view.php?id=1353237>

1. Introduction

This report assesses the risks faced by Pampered Pets in the following scenarios: the current business status, and a proposed digital transformation funded by an external investor aiming to increase the size of the business and its revenue.

The analysis covers operational, market, technical, and regulatory dimensions, and addresses the three questions posed by the client

- 50% growth
- 24% supply chain saving
- 33% customer loss

2. Methodology

Based on the business size, the non-technical audience and the decision sought being directional rather than monetary, the chosen methodology is ISO/IEC 27005:2022 with a qualitative 5x5 likelihood and impact matrix (ISO/IEC, 2022a; Aven and Thekdi, 2025).

A quantitative approach such as FAIR or ALE was rejected because Pampered Pets lacks sufficient historical incident and financial loss data to support meaningful quantitative estimates producing what Cox (2008) describes as the misleading precision of risk-matrix multiplication. A qualitative assessment in this particular case is more appropriate for the size of the organisation.

For the digitalisation assessment, STRIDE was selected as a threat enumeration aid against the proposed e-commerce data flow. Controls are mapped to the NIST Cybersecurity Framework 2.0 (NIST, 2024) and to Cyber Essentials (NCSC, 2023), the UK government guide designed for small organisations.

3. Current business state risk assessment

Pampered Pets operates from a single premises with a flat wireless network shared between a PC used for sales, a warehouse PC and staff personal devices. Sales are 90% face-to-face and 10% email orders with in-person collections.

No documented backup, continuity or information security policy was identified.

Assets	Importance	Reason
Sales PC	High	Records transactions and financial data
Warehouse PC	High	Stores inventory

Wireless Network	High	Connects business
Customer Data	High	Required for orders
Supplier Relationships	High	Currently critical for product availability
Physical Premises	High	Currently generating 90% of revenue

Table 1 In-scope assets

Key risks (likelihood x impact):

ID	Risk	Description	Likelihood	Impact
1	Single-site disruption	Fire, flood or natural disaster disrupting operations; no continuity plan (ISO, 2019).	M	VH
2	Wireless network compromise	Flat network shared with staff personal phones allows lateral movement from compromised devices.	H	H
3	Data loss from warehouse PC	Unsupported PC contains stock records with no evident backup.	H	H
4	Supply concentration	Local suppliers may be affected by common-cause events (animal disease, infrastructure).	M	H
5	UK GDPR non-compliance	Personal data processing lacks documented governance; Article 32 obligation unmet (ICO, 2024).	H	H
6	Revenue concentration	Heavy reliance on face-to-face sales creates demand-side vulnerability.	H	H

Table 2 Current state risk register.

Priority mitigations:

1. Offsite encrypted backup of both PCs, with verified restore quarterly (NIST, 2010).
2. Network segmentation isolating point-of-sale, warehouse, and guest devices.
3. Role-Based Access Control (RBAC) implementation to avoid escalation of privileges.

4. Cyber Essentials certification baseline (boundary firewalls, secure configuration, access control, malware protection, patch management) (NCSC, 2023).
5. Documented data inventory, retention policy, and breach playbook aligned to UK GDPR Articles 30, 33, and 34 (ICO, 2024).
6. Supplier diversification beyond the local radius to reduce common-cause exposure.

4. Digitalisation state risk assessment

Proposed in-scope changes: an integrated ERP system consolidating stock and sales, E-commerce portal with delivery and click-and-collect, a payment service provider integration such as Stripe sized to PCI-DSS SAQ-A (PCI SSC, 2022) and a marketing and analytics tier.

International supply chain is not recommended and therefore, excluded from scope.

STRIDE applied to the proposed e-commerce data flow (Shostack, 2014):

Threat	Property Violated	Threat Definition
Spoofing	Authentication	Credential stuffing against customer accounts; supplier impersonation in order workflows.
Tampering	Integrity	Web application injection altering basket prices or stock counts (OWASP A03).
Repudiation	Non-Repudiation	Disputed orders or refunds without adequate audit logging.
Information Disclosure	Confidentiality	PII and order history exfiltration via misconfigured cloud storage (OWASP A05) (OWASP, 2021).
Denial of Service	Availability	Hosting outage or volumetric attack during seasonal peaks.
Elevation of privilege	Authorisation	Staff ERP accounts exceeding least-privilege scope.

Table 3 List of identified threats

Key risks (likelihood x impact):

ID	Risk	Description	Likelihood	Impact
7	Web application compromise	Exploitation of OWASP Top 10 weaknesses leading to PII loss or order tampering.	H	H
8	Payment data exposure	Reduced by PCI-DSS SAQ-A scoping; residual exposure is contractual and reputational.	L	VH
9	Cloud and third-party concentration	a single platform outage halts trading; a SaaS provider breach exposes data.	M	H
10	Ransomware on integrated ERP	Consolidation creates a single high-value target encrypting operational and financial data simultaneously (Verizon, 2024).	M	VH
11	Staff phishing and account takeover	Broader digital surface with elevated privileges.	H	H
12	Regulatory and project risk	UK GDPR Data Protection Impact Assessment (DPIA). ICO registration and project overrun if scope is not tightly governed.	M	H

Table 4 Digitalisation risk register

Priority mitigations:

1. Procurement of SaaS ERP and e-commerce with vendor SOC 2 or ISO/IEC 27001:2022 evidence (ISO/IEC, 2022b).
2. PCI-DSS SAQ-A via full payment outsourcing; no cardholder data stored on owned systems (PCI SSC, 2022).
3. Multi-factor authentication on all administrative and staff accounts (NIST, 2024).
4. Web application firewall and managed detection on customer-facing services; OWASP ASVS-aligned vendor selection (OWASP, 2021).
5. DPIA executed before launch, with consent and right-of-erasure workflows operational from day one (ICO, 2024).
6. Tested, immutable backups supporting defined RPO and RTO (NIST, 2010).
7. Phishing simulation and Cyber Essentials Plus uplift (NCSC, 2023).

5. Recommendation

A phased digital transformation is recommended, retaining the local supplier model as part of the business' identity.

- Phase 1 (months 1 to 3): ERP, backup, network segmentation, Cyber Essentials, and UK GDPR remediation.
- Phase 2 (months 4 to 9): e-commerce portal, payment outsourcing, DPIA, MFA, and staff training.
- Phase 3 (months 10 to 18): analytics, targeted marketing, and delivery-area expansion once baseline controls are mature. Periodical security audits.

On the client's three questions:

- **50% revenue growth from online presence:** plausible as an upper bound, not a point estimate. Online expansion can deliver double-digit uplift. 50% depends on marketing reach, delivery geography and category demand and it is more defensibly modelled as a range.
- **24% cost reduction from international supply chain:** rejected. The operational saving destroys the locally sourced quality products that constitute the business identity and introduces Brexit-related customs lead time, currency exposure and UK food regulation complexity. The strategic loss exceeds the operating gain.
- **33% customer loss without online provision:** plausible over a multi-year horizon. Post-pandemic behaviour has normalised digital ordering. Convenience-led customers default to competitors that offer this service.

6. Conclusion

Digital transformation is the lower-risk path on a three-year horizon. It reduces existing operational and regulatory exposure while enabling controlled growth. Inaction preserves familiar risk and transfers strategic risk to the market.

Word count: 1,057 (main content excluding titles, contents, references, and table captions)

References

Aven, T. and Thekdi, S. (2025) *Risk Science: An Introduction*. 3rd edn. Oxon: Routledge.

Cox, L.A. (2008) 'What's wrong with risk matrices?', *Risk Analysis*, 28(2), pp. 497-512.

ICO (2024) *Guide to the UK General Data Protection Regulation*. Wilmslow: Information Commissioner's Office. Available at: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/> (Accessed: 26 May 2026).

ISO (2019) *ISO 22301:2019 Security and resilience – Business continuity management systems – Requirements*. Geneva: International Organization for Standardization.

ISO/IEC (2022a) *ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection – Guidance on managing information security risks*. Geneva: International Organization for Standardization.

ISO/IEC (2022b) *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection – Information security management systems – Requirements*. Geneva: International Organization for Standardization.

NCSC (2023) *Cyber Essentials*. London: National Cyber Security Centre. Available at: <https://www.ncsc.gov.uk/cyberessentials/overview> (Accessed: 26 May 2026).

NIST (2010) *Contingency Planning Guide for Federal Information Systems*. SP 800-34 Rev. 1. Gaithersburg, MD: National Institute of Standards and Technology.

NIST (2024) *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29. Gaithersburg, MD: National Institute of Standards and Technology. Available at: <https://doi.org/10.6028/NIST.CSWP.29> (Accessed: 26 May 2026).

OWASP (2021) *OWASP Top 10:2021*. Wakefield, MA: Open Worldwide Application Security Project. Available at: <https://owasp.org/Top10/> (Accessed: 26 May 2026).

PCI SSC (2022) *Payment Card Industry Data Security Standard, v4.0*. Wakefield, MA: PCI Security Standards Council.

Shostack, A. (2014) *Threat Modeling: Designing for Security*. Indianapolis, IN: Wiley.

Verizon (2024) *2024 Data Breach Investigations Report*. New York: Verizon Business. Available at: <https://www.verizon.com/business/resources/reports/2024-dbir-data-breach-investigations-report.pdf> (Accessed: 26 May 2026)